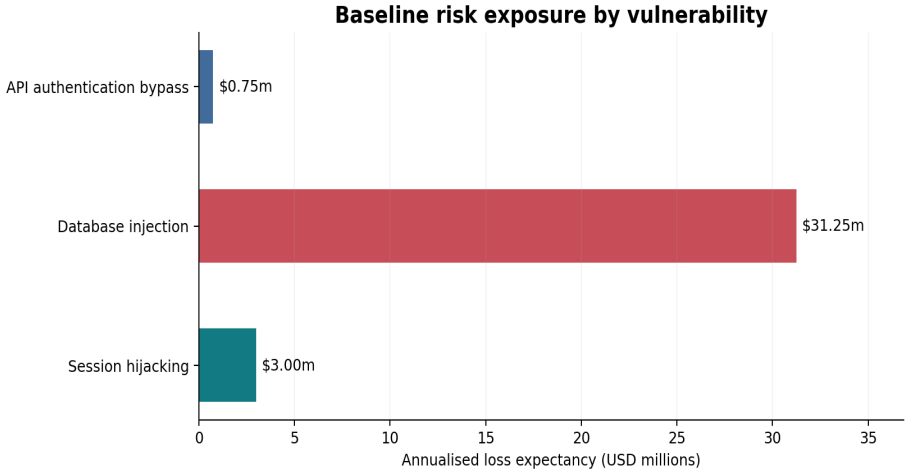
LAB 3B | ADVANCED CYBERSECURITY RISK QUANTIFICATION

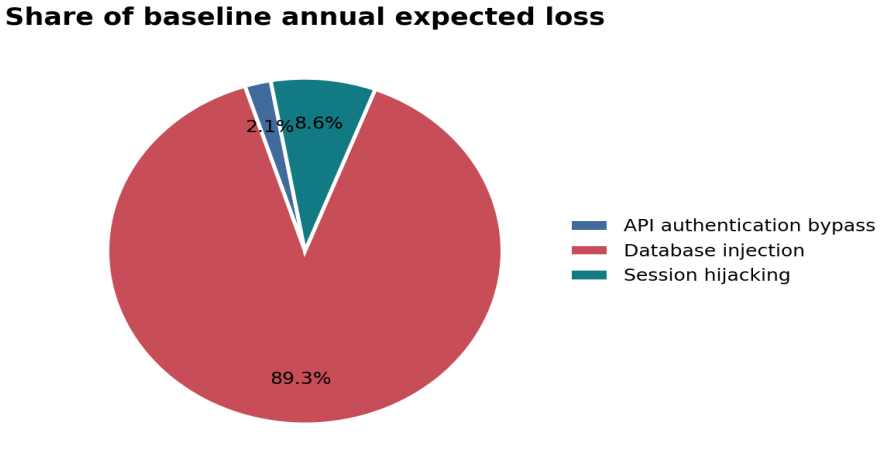
SecureBank Financial - SecureMobile | Prepared by Adediran Eunice Adebukola | C11-26-CGRCE-17595

1. Executive conclusion

The three modelled vulnerabilities produce $35,000,000 in illustrative annualised expected loss. The three specified controls would avoid $26,962,500 in annualised loss, leaving $8,037,500 residual exposure. First-year investment is $805,000 and modelled first-year ROI is 3,249.4%. These are conditional scenario estimates, not observed losses or guaranteed savings.

Risk	Baseline ALE	After control	Financial priority
API authentication bypass	$750,000	$75,000	Moderate
Database injection	$31,250,000	$7,812,500	Critical
Session hijacking	$3,000,000	$150,000	High



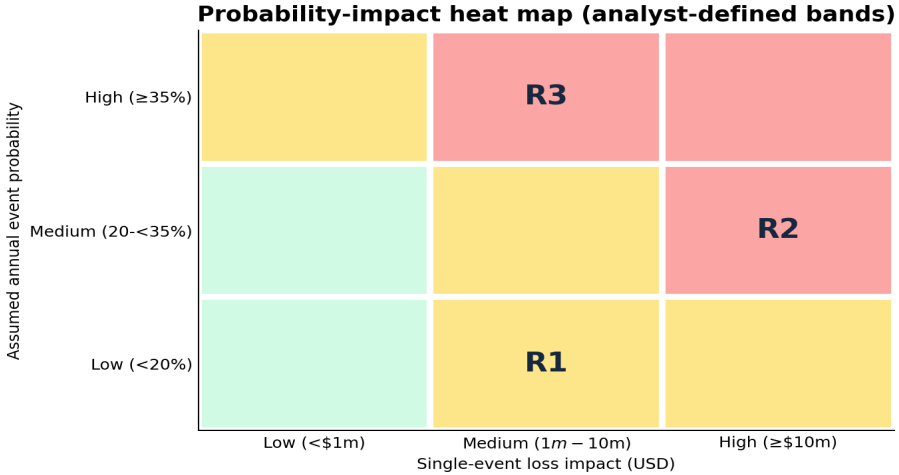


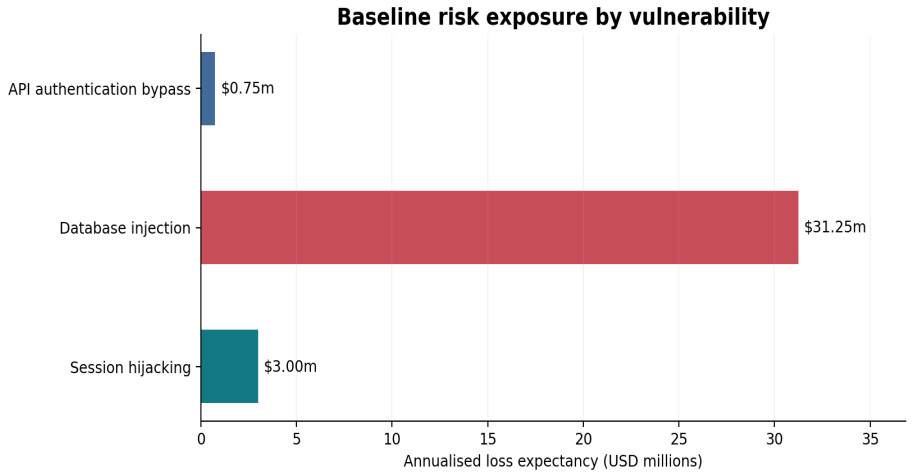
Priority: Database injection dominates baseline ALE (89.3%). The largest loss estimate derives from the assumption that all 500,000 records incur the full $250 per-record cost in one incident. This requires sensitivity testing and validation.

2. Risk method and probability-impact view

Calculation: SLE = maximum incident loss (or exposed units × cost per unit). Assumed ARO = supplied exploit probability × one modelled event/year. ALE = SLE × assumed ARO. This is a Bernoulli, one-event annual scenario; the brief does not provide actual annual event frequency.

Risk	Supplied probability	Model SLE	Assumed ARO	ALE	Priority
API authentication bypass	15%	$5,000,000	0.15	$750,000	Moderate
Database injection	25%	$125,000,000	0.25	$31,250,000	Critical
Session hijacking	40%	$7,500,000	0.40	$3,000,000	High



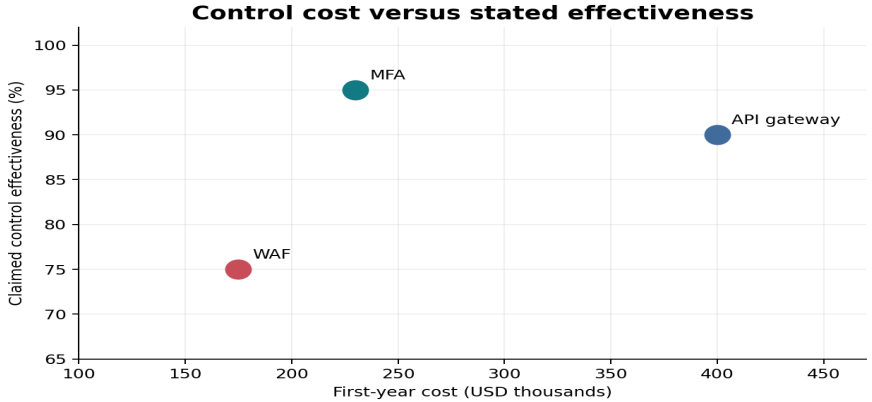


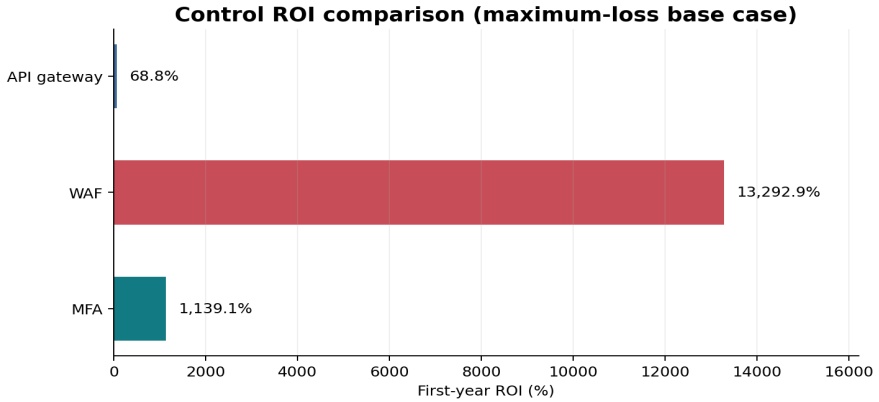
Priority definitions: Critical ALE ≥ $10m/year; High ALE ≥ $1m/year; Moderate below $1m/year. Heat-map probability/impact cutoffs are separately defined and are not official SecureBank risk appetite.

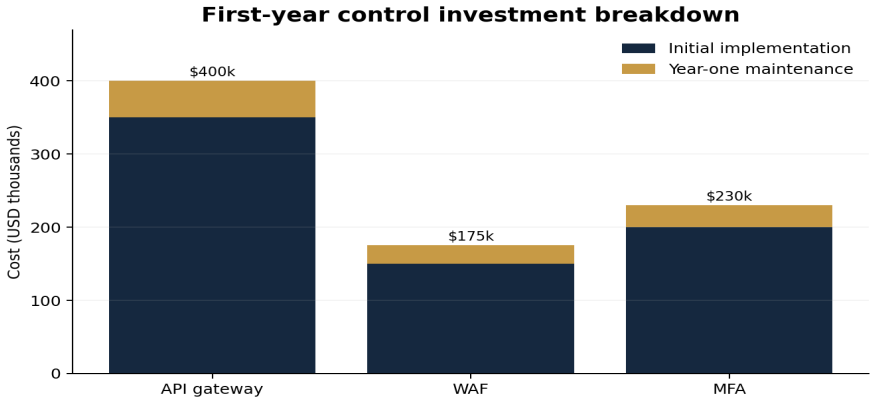
3. Control cost-benefit and residual risk

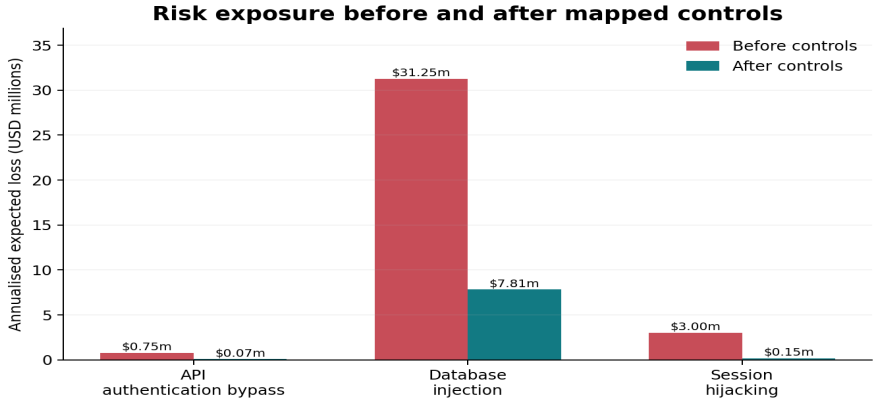
Control-to-risk applicability is an analyst assumption: API gateway → API authentication bypass; WAF → database injection; MFA → session hijacking. Benefits are not double-counted across controls.

Control	Initial	Maint./yr	Avoided ALE/yr	Residual ALE/yr	Yr1 ROI	Payback
API gateway	$350,000	$50,000	$675,000	$75,000	68.8%	6.72 months
WAF	$150,000	$25,000	$23,437,500	$7,812,500	13,292.9%	0.08 months
MFA	$200,000	$30,000	$2,850,000	$150,000	1,139.1%	0.85 months



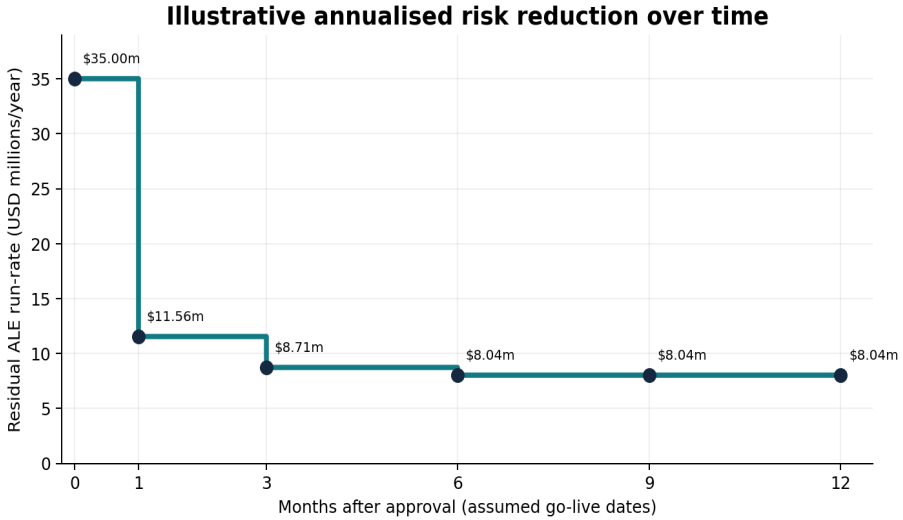


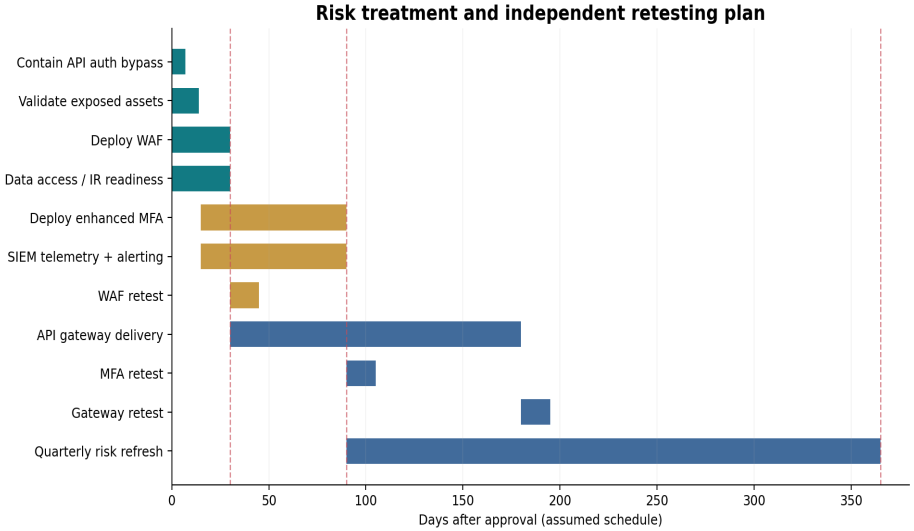




4. Implementation plan, monitoring and independent retest

The schedule is a planning assumption, not a deployment commitment. Day 0 means management approval. Immediate containment of the API bypass should not wait for the gateway project.





Time horizon	Priority actions	Accountable owner	Closure evidence
0-30 days	Contain API auth bypass; deploy WAF; validate injection path and data exposure	API Platform / AppSec / Data Security	Retested WAF rule, secure auth control, attack simulation
31-90 days	Deploy enhanced MFA, centralise SIEM telemetry and alerts	IAM / SOC / Platform	MFA bypass test, alert response metrics, independent retest
91-365 days	Deploy gateway, retest API auth, quarterly risk refresh	API Platform / GRC / AppSec	Independent pentest, risk recalculation, governance sign-off

Continuous monitoring: Alert on suspicious transfers, repeated authentication failures, injection attempts, session anomalies, privilege changes and data-exfiltration signals. Escalate failed controls, material residual exposure and missed remediation milestones to the CISO.

5. Assumptions, sensitivity and financial justification

One-year ROI: (annual avoided ALE - [initial cost + one year maintenance]) / [initial cost + one year maintenance]. Payback: initial investment / (annual avoided ALE - annual maintenance), expressed in years then converted to months. Payback is a steady-state simplification and does not include delayed implementation, discounting or deployment ramp-up.

Realised severity	Baseline ALE/yr	Avoided ALE/yr	Residual ALE/yr	Yr1 net benefit	Yr1 ROI
10%	$3,500,000	$2,696,250	$803,750	$1,891,250	234.9%
25%	$8,750,000	$6,740,625	$2,009,375	$5,935,625	737.3%
50%	$17,500,000	$13,481,250	$4,018,750	$12,676,250	1,574.7%
100%	$35,000,000	$26,962,500	$8,037,500	$26,157,500	3,249.4%

Assumptions and limitations

• Annual event frequency is not supplied. We treat each probability as a one-year chance of at most one event. Different frequencies, multiple events or correlated incidents would change ALE.

• Maximum loss is not a mean incident severity. The 10%, 25%, 50% and 100% scenarios demonstrate dependence on loss magnitude; no empirical loss distribution was supplied.

• API gateway coverage is not proof that an application authentication bypass is fixed. WAF protection does not replace parameterised queries. MFA does not necessarily stop stolen live sessions. Validate control effectiveness independently.

• The model excludes customer attrition, downtime, litigation, incident response, fraud recovery, regulatory jurisdiction differences, vendor deployment constraints and the time value of money.

• Implementation timing, risk bands, event cap, and risk-to-control mapping are analyst assumptions. No budget ceiling or historical loss dataset was provided.

Recommended management decision

Approve technical validation and immediate compensating controls first. Subject to confirmed exploit paths and costs, sequence WAF, MFA and API gateway remediation; assign accountable owners and require independent retesting before closing findings. Recalculate the risk model using observed loss and incident data before treating the ROI figures as investment-grade forecasts.

Source: Supplied Lab 3b official brief and instructor guidance screenshot. All calculations and visualisations are derived from supplied inputs and explicitly identified modelling assumptions. No external threat-frequency or cost dataset has been introduced.